

Blind OS command injection with time delays

Topic: Command Injection | Difficulty: Practitioner

Description

The feedback submission form passes the email field to an OS shell command without sanitization. The application does not return command output, but injection can be confirmed by injecting a time-delay command (ping). A 10-second response delay confirms successful blind OS command injection.

Steps to Exploit

1. Navigate to the feedback / contact form.
2. Fill in all required fields with valid data.
3. Intercept the POST submission request in Burp Suite.
4. Locate the 'email' parameter in the request body.
5. Modify the email value to: `|| ping -c 10 127.0.0.1 ||`
6. Forward the request and measure the response time.
7. A ~10 second delay confirms blind OS command injection.

Proof of Concept

Payload (email field):

```
|| ping -c 10 127.0.0.1 ||
```

Effect:

```
Server responds after ~10 seconds (10 ICMP packets sent to loopback).
```

Impact

- Confirmed arbitrary OS command execution despite no visible output.
- Can be escalated to full compromise via out-of-band data exfiltration.
- Potential for reverse shell establishment.
- Risk of sensitive file exfiltration and internal network reconnaissance.

Mitigation / Remediation

1. Never pass user-controlled input directly to shell execution functions.
2. Sanitize all input fields including email against shell metacharacters.
3. Use language-native libraries for email validation instead of shell commands.
4. Monitor anomalous response times and outbound network traffic for early detection.

CVSS Score

CVSS v3.1: 7.5 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CVSS Justification

- Attack Vector: Network - exploitable via standard HTTP form submission.

- Attack Complexity: Low - no special configuration required.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality: High - can escalate to full filesystem access.
- Integrity / Availability: None - time-delay proof-of-concept only.